Studio Nx

AI 구현 설명 36 — P1-05 로그인 API

2026-10-07

AI 구현 설명 36 — P1-05 로그인 API (JWT 발급 · 리프레시 쿠키 · 재발급 · 로그아웃)

항목	내용
작성	Claude (AI) · 2026-10-07
작업	P1-05 로그인 — PRD 01 FR-103 · FR-104 · FR-105 · FR-108 · FR-109
브랜치	`feature/phase1/p1-05-login-jwt`
바꾼 파일	`core/security.py` · `services/auth_service.py` · `api/v1/auth.py`
진행 방식	**함수 하나씩** 구현 → 사용자 검토 → 다음
함수별 설명	`docs/ai-notes/backend(fastAPI_Python)/P1-05 - 로그인 API/26 ~ 34` (md · PDF), 합본 `P1-05 login api.pdf`
실제 사이트 시험	37 p1-04 05 site test.md — 10개 모두 통과
이전 문서	35 p1-04 signup api.md

1. 한 일

API	하는 일
`POST /api/v1/auth/login`	이메일 · 비밀번호 확인 → Access Token(본문, 30분) + Refresh Token(HttpOnly 쿠키, 3일)
`POST /api/v1/auth/refresh`	리프레시 쿠키로 새 Access Token
`POST /api/v1/auth/logout`	리프레시 쿠키 삭제 (204)

이로써 **P1-02 JS 의 재발급 · 로그인 확인 · 로그아웃이 실제 서버와 함께 동작한다** (37 에서 확인).

2. 항목 9개

#	파일	항목	하는 일	설명
26	`security.py`	`create_access_token()` · `_create_token()`	30분 JWT (`sub` · `type` · `iat` · `exp`)	26
27	`security.py`	`create_refresh_token()`	3일 JWT (`type: refresh`)	27
28	`security.py`	`decode_refresh_token()`	05 `_decode_token` 으로 한 줄	28
29	`auth_service.py`	`authenticate()` · `invalid_credentials()`	로그인 확인 · 가짜 해시로 시간 맞추기 · `last_login_at`	29
30	`auth_service.py`	`get_active_user()`	재발급 전 활동 회원인지	30
31	`auth.py`	`set_refresh_cookie()` · `clear_refresh_cookie()`	HttpOnly · Path · SameSite · (배포) Secure, 체크 = 3일 / 아니면 세션	31
32	`auth.py`	`POST /auth/login`	29 → 27 · 31 → 26	32
33	`auth.py`	`POST /auth/refresh`	쿠키 → 28 → 30 → 26	33

#	파일	항목	하는 일	설명
34	`auth.py`	`POST /auth/logout`	31 로 쿠키 삭제, 로그인 확인 없음	34

3. 토큰 두 개가 움직이는 모습

순서	일어나는 일	항목
①	로그인 모달 → `POST /auth/login`	32 → 29
②	본문 Access(30분) → JS 메모리 / 쿠키 Refresh(3일 · HttpOnly)	26 · 27 · 31
③	API 요청마다 `Authorization: Bearer <Access>`	P1-02 JS 02 · P1-03 06
④	페이지 이동 · 30분 만료 → `POST /auth/refresh` (쿠키 자동)	33 → 28 → 30 → 26
⑤	Sign Out → `POST /auth/logout` → 쿠키 삭제 + JS 메모리 비움	34 · P1-02 JS 08
⑥	3일이 지나면 쿠키 · 토큰 만료 → 다시 로그인	

4. 보안 정리

항목	한 일	확인
실패 이유 숨김	비밀번호 틀림 · 없는 이메일 · 탈퇴 · 형식 틀림 → 같은 401 문구	37 §05
응답 시간 맞춤	없는 이메일도 가짜 해시로 비교 (약 0.19초)	37 §05 — 191 · 192 · 189ms
정지 사실은 본인에게만	비밀번호가 맞을 때만 403	29 시험
Refresh 를 JS 에서 숨김	`HttpOnly` 쿠키 — `document.cookie` 에 안 보임	37 §04
Refresh 가 다니는 곳 좁힘	`Path=/api/v1/auth` · `SameSite=lax` · 배포에서 `Secure`	31 시험
토큰 종류 구분	Access ↔ Refresh 서로 바꿔 쓸 수 없음	27 · 28 시험
탈퇴 · 정지 즉시 반영	재발급 때 30 이 회원 상태 확인	33 시험

남은 한계 (Phase 1 범위 밖): 로그아웃은 이 브라우저의 쿠키만 지운다. 이미 복사된 리프레시 토큰을 끊으려면 서버에 무효 토큰 목록이 필요하다 (34 §5).

5. 템플릿과 달라진 점

항목	템플릿	구현	이유
토큰 `iat`	없음	넣음	토큰이 매번 달라지고, 나중에 "이 시각 이전 토큰 무효" 처리 가능
토큰 만들기	함수마다	`_create_token()` 공용	05 `_decode_token` 과 짝
쿠키 지우기	경로만	속성까지 같게	브라우저가 같은 쿠키로 확실히 인식
리프레시 교체 (rotation)	선택 사항	하지 않음	로그인 후 3일이면 끝 — 단순하게
06 이 30 을 부르기	선택 사항	하지 않음	06 은 검토가 끝난 코드

6. 시험

파일	대상	시험 수
`tests/test_security.py`	05 · 26 · 27 · 28	25
`tests/test_auth_service.py`	17 ~ 21 · 29 · 30 (실제 MySQL)	48
`tests/test_auth_cookies.py`	31	5
`tests/test_auth_routes.py`	22 ~ 24 · 32 ~ 34 (실제 앱 + MySQL)	43

전체 시험 234개 통과, `ruff` 검사 통과. 인증 파일 3개에 남은 `NotImplementedError` 0개. 실제 사이트 시험 10개 통과 (37).

7. 다음 작업이 쓰는 곳

작업	쓰는 것
P1-07 가입 · 로그인 JS	22 ~ 24 · 32 의 요청 · 응답, `setAccessToken`, `#login?next=`
P1-08 회원 정보	`CurrentUser` (06) — 37 §07 에서 통과 확인
P1-09 비밀번호 변경 · 탈퇴	16 · 14 · 15, 탈퇴 뒤 30 이 재발급을 막음